

Contentious Chamber

Decision on the merits 136/2023 of September 28, 2023

File number: DOS-2022-00360

Subject: Complaint regarding the processing of personal data in the context of an investigation into fraud

The Contentious Chamber of the Data Protection Authority, composed of Mr. Hielke Hijmans, President, and Messrs. Jelle Stassijns and Frank De Smet, Members; Considering Regulation (EU) 2016/679 of the European Parliament and of the Council of April 27, 2016, on the protection of natural persons with regard to the processing of personal data and on the free movement of such data, and repealing Directive 95/46/EC (General Data Protection Regulation), hereinafter "GDPR";

Considering the law of December 3, 2017, establishing the Data Protection Authority, hereinafter "LCA";

Considering the internal regulations as approved by the House of Representatives on December 20, 2018, and published in the Belgian Official Gazette on January 15, 2019;

Considering the documents in the file;

Has made the following decision regarding:

The complainant:

Mr. X, hereinafter "the complainant";

The defendant: Y, represented by counsel Mr. Bert Beelen, whose office is located at 3000 LEUVEN, Justus Lipsiusstraat 24, hereinafter "the defendant".

Decision on the merits 136/2023 - 2/22

I. Facts and Procedure

1.

On January 20, 2022, the complainant filed a complaint with the Data Protection Authority against the defendant.

On August 22, 2020, the complainant sent an email to the defendant's services indicating that he had previously received two letters from the defendant, namely on January 29, 2020, and March 10, 2020. In this regard, the complainant noted that there was a difference in the use of the font and the type of numbers between the two letters.

The complainant informed the defendant and wanted to know if the defendant's letter templates had changed. Since this was not the case, this email from the complainant was considered by the defendant as a notification of a potential fraud case.

Given the legal obligation to examine notifications of potential fraud, an investigation was initiated. Since the complainant and his ex-wife are known to the defendant, the complainant's ex-partner was also contacted during the investigation into the potential fraud. On November 14, 2021, the complainant filed a complaint with the defendant regarding the transmission of the emails in question – with the name and email address of the complainant – to his ex-partner. This complaint was described by the defendant as very confusing. The defendant's services therefore responded to the complainant on November 24, 2021, requesting clarification of his complaint in an interview. This interview took place on November 30, 2021. On December 14, 2021, the complainant was informed by the defendant that the examination of his complaint had not yet been concluded and that the defendant would respond to him as soon as possible. On January 10, 2022, the response to the complainant's complaint was transmitted to him. It emerged from the investigation that the difference in font in the templates resulted from the use of a different printer and that there was therefore no question of fraud. The defendant responded to additional questions from the complainant on January 12, 2022, and January 18, 2022, respectively on January 17, 2022, and January 24, 2022. Since the complainant believed that the responses provided by the defendant were insufficient, he filed the present complaint.

2.

On January 31, 2022, the complaint was declared admissible by the First Line Service based on

Articles 58 and 60 of the LCA, and the complaint was forwarded to the Contentious Chamber under Article 62, § 1 of the LCA.

3.

On February 22, 2022, in accordance with Article 96, § 1 of the LCA, the request from the Contentious Chamber to conduct an investigation was forwarded to the Inspection Service, along with the complaint and the inventory of documents.

4.

On April 6, 2022, the investigation by the Inspection Service was concluded, the report was attached to the file, and it was forwarded by the Inspector General to the President of the Contentious Chamber (Article 91, § 1 and § 2 of the LCA).

Decision on the Merits 136/2023 - 3/22

The report contains findings related to the subject of the complaint and concludes that there is:

1. a violation of Article 5, Article 24.1, and Article 25.1 and 25.2 of the GDPR; and
2. a violation of Article 12.1, 12.2, and 12.6 of the GDPR, Article 13.1 and 13.2 of the GDPR, and Article 14.1 and 14.2 of the GDPR, Article 5.2 of the GDPR, Article 24.1 of the GDPR, and Article 25.1 of the GDPR.

The report also contains findings that go beyond the subject of the complaint.

The Inspection Service finds, in broad terms, that there is:

3. a violation of Article 30.1 of the GDPR; and
4. a violation of Articles 38.1, 38.3, and 39.1 of the GDPR.

5.

On April 12, 2022, the Litigation Chamber decides, pursuant to Article 95, § 1, 1° and Article 98 of the LCA, that the case may be addressed on the merits.

6.

On February 12, 2022, the parties concerned are informed by email of the provisions as set out in Article 95, § 2 as well as Article 98 of the LCA. They are also informed, pursuant to Article 99 of the LCA, of the deadlines for submitting their conclusions. For the findings related to the subject of the complaint, the deadline for the receipt of the defendant's response conclusions was set for May 24, 2022, that for the complainant's reply conclusions for June 14, 2022, and finally, that for the defendant's reply conclusions for July 5, 2022.

Regarding the findings going beyond the subject of the complaint, the deadline for the receipt of the defendant's response conclusions was set for May 24, 2022.

7.

On April 19, 2022, the complainant accepts all communications related to the case by electronic means.

8.

On May 2, 2022, the defendant accepts all communications related to the case by electronic means.

9.

On May 23, 2022, the Litigation Chamber receives the defendant's response conclusions regarding the findings related to the subject of the complaint. First, the defendant contests the jurisdiction of the Data Protection Authority (hereinafter: DPA) by asserting that the Flemish Supervisory Commission (Vlaamse Toezichtcommissie, hereinafter: VTC) is competent to handle this matter, or that a preliminary question should be referred to the Constitutional Court. On the merits, the defendant does not contest the findings of the Inspection Service but emphasizes that the violations identified have since been remedied. These conclusions also include the defendant's response regarding the findings made by the Inspection Service outside the scope of the complaint. The defendant does not contest these findings either, but also indicates that it has taken the necessary steps in the meantime to remedy these violations.

10.

On June 27, 2022, the Litigation Chamber receives notification from the complainant that

he will not submit any reply conclusions.

11.

Subsequently, the defendant also did not submit any duplicate conclusions.

12.

On May 8, 2023, the parties are informed that the hearing will take place on June 23, 2023.

13.

On June 23, 2023, the parties are heard by the Litigation Chamber.

14.

On June 28, 2023, the minutes of the hearing are submitted to the parties.

15.

On July 3, 2023, and July 5, 2023, the Litigation Chamber receives some remarks from the complainant regarding the minutes, which it decides to include in its deliberation.

16.

The Litigation Chamber does not receive any remarks from the defendant regarding the minutes.

II. Reasoning

II.1. Jurisdiction of the Litigation Chamber

17.

The defendant argues that the Data Protection Authority, including its bodies and thus also the Litigation Chamber, would not be competent in this matter. In fact, the defendant claims that the Flemish Supervisory Commission is competent to monitor compliance with legal (and constitutional) provisions and other regulatory provisions regarding the protection of personal data by an entity such as that referred to in Article 10/1, § 1 of the decree of July 18, 2008, concerning the electronic exchange of administrative data (hereinafter: the "decree of July 18, 2008") when this monitoring falls under a federated competence.

18.

Pursuant to Article 57.1.f) of the GDPR and Article 51.1 of the GDPR, all Member States define which public authority will carry out the supervisory tasks, and it is possible to designate more than one supervisory authority. Following the GDPR, the law of December 3, 2017 establishing the Data Protection Authority (hereinafter the "LCA") was adopted.

19.

The DPA was therefore established under Article 4, § 1, first paragraph of the LCA. It is true that, as explicitly confirmed by Article 4, § 1, second paragraph of the LCA, the federated entities themselves can also create data protection authorities, as has been

Decision on the merits 136/2023 - 5/22

also indicated the Council of State in its opinion no. 61.267/2/AV of June 27, 2017 3 (see below). In execution of this article, the Flemish legislator established the Flemish Supervisory Commission (Vlaamse Toezichtcommissie) by Article 10/1 of the decree of June 8, 2018.4

20. In its judgment of October 26, 2022, the Market Court held that the argument raised by the defendant, who contests the competence of the APD to ensure compliance with the GDPR in relation to municipalities and claims that only the Flemish Supervisory Commission is competent to oversee the processing of personal data by Flemish municipalities and to handle complaints in this regard in accordance with Article 10/1, § 1 and Article 10/7, § 4 of the decree of July 18, 2008 on the electronic exchange of administrative data, is legally unfounded. In this regard, the Market Court confirms that the APD, and thus the Litigation Chamber, is indeed competent to hear a complaint concerning the processing of personal data carried out by a Flemish municipality.

II.2. Article 5 of the GDPR

II.2.1. Article 5. 1.f) of the GDPR

II.2.1.1.

Findings in the inspection report

21.

The first element subject to investigation by the Inspection Service concerns the assessment of the

extent to which the defendant has taken the necessary technical and organizational measures to comply with the fundamental principles of data protection, in accordance with Article 5.1.f) of the GDPR.

22.

The Inspection Service finds that these obligations have not been met and argues the following considerations:

- the defendant has not provided any document certifying the measures and decisions taken to ensure these principles relating to personal data. The documents provided by the defendant only concern the security of personal data (Article 5.1.f) of the GDPR);

- The documents "Security Charter" and "Security Principles" of the defendant state that they have not yet been approved;

- The documents "Information Security Plan" and "Proposal regarding security at the College of Mayors and Aldermen" do not indicate the date of their

3 Opinion of the Council of State no. 61.267/2 of June 27, 2017 on a draft law "reforming the Commission for the Protection of Privacy," role number 7.1-7.2. See also, for example, the opinion of the Council of State no. 66.033/1/AV of June 3, 2019 on a draft decree of the Flemish Government of December 10, 2010 "implementing the decree on private placement, regarding the establishment of a registration obligation for sports agents," 4; Opinion of the Council of State no. 66.277/1 of July 2, 2019 on a draft decree of the Flemish Government "regarding the modalities concerning the processing, retention, and evidential force of electronic data relating to allowances under family policy," 6-7.

4 M.B., June 26, 2018.

Decision on the Merits 136/2023 - 6/22

approval and each footer further indicates "Stad Leuven" (City of Leuven), which is not the defendant;

- The document "Report of the Information Security Steering Group" does not indicate the date of its approval nor the decisions that were made by the defendant;

- The document "BCSS Compliance via the BCSS Form" does not indicate the date of its approval nor the decisions that were made by the defendant;

- Training on "professional secrecy" for the defendant's employees is useful, but in itself insufficient to raise their awareness regarding the importance of adequate security for personal data.

II.2.1.2.

Defendant's Position

23.

In its conclusions, the defendant responds to these findings. The defendant argues that additional measures and decisions have been taken that indeed ensure compliance with the principles regarding personal data, both in terms of internal organization and privacy policy. A full-time internal information security advisor has been hired, and a 2021 information security plan emphasizing IT security has been established. The principles and timeline of the current 2021 information security plan have been included in the explanation provided to the College of Mayors and Aldermen. Policies and frameworks have been established for local administrations as a whole (such as the city itself but also Y and its non-profit organizations). Furthermore, a plan with technical, legal, and organizational aspects has been established for 3 years. During the municipal council meeting on April 26, 2021, an additional budget was allocated for information security and privacy protection. On June 28, 2021, the cooperation agreement with Interleuven was approved, which provides for the support of a data protection officer for the City of Leuven and notably Y. The security charter, including the privacy policy, has been clarified and verified. In addition to training on professional secrecy, training on data protection has been organized for the staff. An internal action on phishing has been implemented to

raise employees' awareness of the dangers of phishing. Due to technical issues, this action had not yet been deployed across the entire organization at the time of the exchange of conclusions. The report of the information security steering group will be approved at the next meeting on June 23, 2022. Regarding the document "BCSS Compliance via the BCSS Form," the defendant indicates that the date of signature is mentioned next to each individual signature. The general director signed the document on August 4, 2021. The findings and any adjustments that were listed based on the responses to the BCSS questionnaire have been incorporated into the preparation of the new information security plan. Finally, the defendant asserts that Y's work regulations firmly sanction violations of the GDPR and that professional secrecy, to which every employee of Y is bound, is penalized under Article 458 of the Penal Code.

24.

On June 21, 2023, and during the hearing, the defendant submitted the information security plan as well as its approval decree from the College of Mayors and Aldermen dated June 16, 2023.

II.2.1.3.

Assessment by the Contentious Chamber

25. Under Article 5.1.f) of the GDPR, personal data must be protected against unauthorized or unlawful processing and against accidental loss, destruction, or damage ("integrity and confidentiality").

26. The Contentious Chamber observes that the Inspection Service had identified various shortcomings, both regarding internal organization and data protection policy. As the defendant also pointed out in its conclusions, additional measures and decisions have been taken to ensure compliance with data protection principles. Regarding the information security unit, it has been divided into a steering group at the strategic level with members of management and experts on one hand, and a working group at the tactical and operational level with, among others, staff members and experts on the other hand.

27. Regarding the data protection policy, a full-time internal information security advisor has been hired to support the external data protection officer, and an information security plan has been established, particularly emphasizing technical measures regarding IT security.

28. The Contentious Chamber also refers to the information security plan that was submitted on June 21, 2023. The Contentious Chamber notes that this approved information security plan outlines the data protection policy for personal data and sets forth its practical implementation.

29. The Contentious Chamber takes into account the statements of the defendant and the documents submitted during the hearing and concludes that there is a historical violation of Article 5.1.f) of the GDPR, given that the identified violations have since been remedied.

30. The Contentious Chamber emphasizes that the defendant, due to its status as a public service, has a role model function in terms of compliance with legislation regarding the protection of personal data. In this context, the fact that this public service processes a large amount of (sensitive) personal data also plays a role.

Decision on the Merits 136/2023 - 8/22

In accordance with the principle of "lead by example," it must therefore always ensure compliance with this legislation, particularly with the essential provisions mentioned above of the GDPR. One can expect a properly functioning public service to have the necessary policy documents that meet the requirements of the GDPR.

II.2.2. Article 5. 1. b) - e) of the GDPR

31. Regarding the other fundamental principles set out in Article 5.1.b) to e) of the GDPR, the Contentious Chamber finds that the Inspection Report does not contain sufficient indications or evidence to suggest that there has been a violation of these principles.

II.3. Article 5.1.a (transparency), Article 12.1, 12.2 and 12.6, Article 13.1 and 13.2, Article 14.1 and 14.2 of the GDPR

II.3.1. Findings of the Inspection Service

32. In execution of the principle of transparency of Article 5.1 a) of the GDPR, it is necessary, based on Article 12.1, Article 13.1 and 13.2, and Article 14.1 and 14.2 of the GDPR, that the data controller, in this case the defendant, provides the data subjects with concise, transparent, and understandable

information about the personal data being processed. As the data controller, the defendant must apply Articles 12, 13, and 14 of the GDPR.

33. In this case, the Inspection Service concludes that the defendant has violated Article 12.1, 12.2 and 12.6 of the GDPR, Article 13.1 and 13.2 of the GDPR, and Article 14.1 and 14.2 of the GDPR, given that the privacy statement contained inaccurate information and was incomplete.

34. First, the inspection report concludes that the defendant's privacy statement is not transparent and understandable, as required by Article 12.1 of the GDPR, and contains inaccurate information from a data protection perspective, due to the following findings:

- First, the defendant creates in its privacy statement the false impression that it fully complies with the GDPR. However, the report indicates that the defendant commits various violations of the GDPR;
- Second, the defendant's privacy statement incorrectly states that for the exercise of their rights, data subjects will receive a response "no later than 30 days after receiving your request and proof of identity"; and

Decision on the Merits 136/2023 - 9/22

- Third, the defendant's privacy statement is not clear and therefore not transparent for the data subjects regarding:

- i. the concepts of "personal data" and "data" which are used interchangeably,
- ii. the purposes and legal grounds for processing, as these are only described in vague terms,
- iii. the transfer of personal data, as there is no transparent information regarding the possible legal basis for transfer to third parties;
- iv. the retention period of personal data, as it is not clear what the (legal) retention periods are in practice, and
- v. the changes that have been made, as the date of the last update and what was specifically modified are not mentioned.

35. Secondly, the Inspection Service also finds that the defendant's privacy statement is incomplete because not all the information that must be mentioned under Articles 13 and 14 of the GDPR is actually provided, as no information is communicated regarding:

- the contact details of the data protection officer;
- the purposes of processing as well as the legal basis for processing;
- the recipients or categories of recipients; and
- the retention period or the criteria used to determine that period.

II.3.2. Position of the Defendant

36. In its conclusions, the defendant asserts that its entire privacy statement has been completely revised to address all the comments made by the Inspection Service in the inspection report, thereby complying with Article 12.1 of the GDPR. Similarly, the privacy statement has been supplemented so that the following data is no longer missing: the contact details of the data protection officer, the purposes of processing and the legal basis for processing, the recipients or categories of recipients of personal data, as well as the retention period or the criteria for determining that period. The defendant emphasizes that it has always demonstrated its willingness to comply with all provisions of the GDPR. After receiving the inspection report, the defendant took the necessary steps to remedy the violations.

Decision on the Merits 136/2023 - 10/22

II.3.3. Evaluation by the Contentious Chamber

37. The Contentious Chamber must assess whether the defendant's privacy statement meets the requirements as prescribed by Article 5.1.a (transparency), Articles 12.1, 12.2, 12.6, Articles 13.1 and 13.2, and Articles 14.1 and 14.2 of the GDPR.

38. Article 12.1 of the GDPR stipulates that the data controller "takes appropriate measures to provide any information referred to in Articles 13 and 14 [...] regarding the processing to the data subject in a concise, transparent, understandable, and easily accessible manner, using clear and plain language, particularly for any information specifically addressed to a child."

39. In this regard, the Contentious Chamber refers to the guidelines on transparency from the "Article 29" Working Party on Data Protection, which state the following: "Every company with a website should publish a statement or notice regarding privacy on its site. A direct link to this statement or notice regarding privacy should be clearly visible on every page of this website under a commonly

used term (such as 'Privacy', 'Privacy Policy', or 'Privacy Notice')." The Data Protection Group asserts that "all information addressed to a data subject should also be accessible in a single location or in the same document (in paper or electronic format) that can be easily consulted by that person if they wish to review all the information addressed to them."

40. The Contentious Chamber notes that the complainant was informed of the disputed processing via the privacy statement available on the website. However, the Contentious Chamber observes that not all essential information was communicated in an understandable manner.

41. First, the Contentious Chamber notes in this regard that the privacy statement does not sufficiently detail the specific legal basis(es) and purposes of the processing, as well as the personal data of the data subjects that are used for this purpose, as required by Articles 13.1, 13.2, and 14.1 of the GDPR. The Contentious Chamber finds that while the privacy statement does mention these elements, the manner in which it does so is not adequate.

5 Predecessor of the European Data Protection Board (EDPB).

6 "Article 29" Working Party on Data Protection, Guidelines on Transparency under Regulation (EU) 2016/679, revised and approved version on April 11, 2018 (available at: https://www.cnil.fr/sites/default/files/atoms/files/wp260_guidelines-transparence-fr.pdf), point 11.

7 "Article 29" Working Party on Data Protection, Guidelines on Transparency under Regulation (EU) 2016/679, revised and approved version on April 11, 2018 (available at: <https://ec.europa.eu/newsroom/article29/items/622227>), point 17.

Decision on the merits 136/2023 - 11/22

understandable and transparent for the individuals concerned, given that the individual concerned does not clearly know which data is processed for which purpose nor under which legal basis this occurs. Ideally, the data controller should provide a statement of the different purposes clearly described for which it processes personal data, with each time the mention of the (categories of) personal data that are processed for this purpose, through which source they were obtained, the duration of their retention, and the (categories of) recipients with whom they are (or may be) shared.⁸

42. Secondly, the Contentious Chamber notes that the privacy statement does not clearly mention the retention periods of the concerned personal data or the criteria for determining them, as required by Article 13.2.a) and Article 14.2.a) of the GDPR. As also indicated in the guidelines of the Data Protection Board, a reference to legal retention periods is not sufficient. They specify that "The retention period (or the criteria for determining it) may be dictated by various factors such as regulatory requirements or industry guidelines, but it should be formulated in such a way that the individual concerned can assess, depending on the situation in which they find themselves, what the retention period will be regarding specific data or in the case of specific purposes."⁹

43. Thirdly, the Contentious Chamber emphasizes that within the framework of the principle of transparency, the data controller must, under Article 12.2 of the GDPR, facilitate the exercise of the rights of the individual concerned under – in particular – Article 15 of the GDPR.

44. The Contentious Chamber notes that the current privacy statement on the defendant's website¹⁰ contains the following passage:

"If we are not convinced of your identity, we may ask you to present or send a copy of proof of identity."

45. As explained by the EDPB, a request to exercise rights under Chapter III of the GDPR can, in principle, only concern the personal data of the individual concerned who submits the request.¹¹

46. Although the GDPR does not impose any requirements regarding the methods for establishing the identity of the individual concerned, Article 12.6 of the GDPR provides for the possibility for the

⁸ This allows the individual concerned to concretely request, possibly via a request for access rights, with which individual recipients the personal data are shared, see in particular CJEU, January 12, 2023, Österreichische Post AG, C-154/21, ECLI:EU:C:2023:3.

⁹ Guidelines on transparency under Regulation (EU) 2016/679, WP260rev01, established on November 29, 2017, p. 25.

¹⁰ Consulted on September 18, 2023.

¹¹ EDPB, Guidelines 01/2022 on data subject rights - Right of access, v1.0, January 18, 2022, paragraph 46.

Decision on the Merits 136/2023 - 12/22

The data controller may request, where applicable and to the extent that it can demonstrate that it is unable to identify the data subject making the request, additional information from the data subject before responding to their request. However, in this regard, the general rule is that a data controller cannot request more personal data than is necessary to enable this identification and that the use of this information must remain strictly limited to the purpose of responding to the requests of the data subjects.¹² Recital 57 of the GDPR further specifies that the data controller is not obliged to collect additional identification data solely in order to be able to respond to a request from a data subject.

47. In other words, a data controller that duly demonstrates - as required by the accountability obligation under Article 5.2 of the GDPR - that it cannot identify a data subject may lawfully refuse to respond to a rights exercise request but must, in such cases, inform the data subject of this situation and provide them with the additional information needed for identification, in accordance with Article 11.2 of the GDPR.¹³

48. The European guidelines also specify that in cases where it requests additional information necessary to confirm the identity of the data subject, the data controller must assess each time which information will concretely allow it to confirm the identity of the data subject. Where applicable and to the extent that it is proportionate, it may ask the requester additional questions or request the data subject to provide some additional information.¹⁴

49. The defendant must therefore always carry out such a balancing exercise when requesting additional identification data in the context of a data subject's rights exercise. It does not appear from the complaint, the inspection report, or other documents in the file that the defendant requested additional identification data in the context of the rights exercise by the complainant. The Litigation Chamber emphasizes that it agrees with the Inspection Service when it states that a general provision regarding the communication of additional identification data, as initially formulated in the privacy statement, is not proportionate in light of the aforementioned European guidelines.

12 EDPB, Guidelines 01/2022 on data subject rights - Right of access, v1.0, January 18, 2022, paragraphs 59-60.

13 EDPB, Guidelines 01/2022 on data subject rights - Right of access, v1.0, January 18, 2022, paragraph 64.

14 EDPB, Guidelines 01/2022 on data subject rights - Right of access, v1.0, January 18, 2022, paragraph 65.

Decision on the Merits 136/2023 - 13/22

50. In light of all these elements, the Litigation Chamber finds a violation of Article 5.1.a) (transparency), Article 12.1, Article 13.1 and 13.2, as well as Article 14.1 and 14.2 of the GDPR regarding the unclear mention of the necessary information, as well as the non-explicit mention of the retention period in the privacy statement. The Litigation Chamber finds that there was a violation of Article 12.2 and 12.6 of the GDPR insofar as the aforementioned general provision in the privacy statement analyzed by the Inspection Service regarding the communication of additional identification data is not proportionate in light of the aforementioned European guidelines, but that this has since been remedied in the new privacy statement.

II.4. Article 5.2, Article 24.1 and Article 25.1 and 25.2 of the GDPR.

II.4.1. Findings in the Inspection Report

51. The data controller must comply with the principles of Article 5 of the GDPR and be able to demonstrate this compliance. This follows from the principle of accountability under Article 5.2 in conjunction with Article 24.1 of the GDPR. Under Articles 24 and 25 of the GDPR, each data controller must take appropriate technical and organizational measures to ensure and be able to demonstrate that processing is carried out in accordance with the GDPR.

52. In its inspection report, the Inspection Service finds that Articles 5.2, 24.1, 25.1 and 25.2 of the GDPR have been violated.

53. First, the Inspection Service finds that the defendant has not complied with its obligations imposed by Articles 5.2, 24.1, 25.1 and 25.2 of the GDPR. In this regard, the Inspection Service refers to the measures and decisions taken to ensure compliance with the principles regarding personal data as

well as the documents and shortcomings as outlined in section II.2.1.1.

54. Second, the Inspection Service concludes that the defendant does not demonstrate what appropriate technical and organizational measures have been taken to meet the information obligations as defined in Articles 12 to 14 of the GDPR, as outlined in section II.3.1 of this decision.

II.4.2. Position of the Defendant

55. As outlined in section II.2.1.2 and in section II.3.2, the defendant claims that by the time the conclusions were introduced, the identified violations had already been remedied.

II.4.3. Assessment by the Litigation Chamber

Decision on the Merits 136/2023 - 14/22

56. The Contentious Chamber recalls that each data controller must comply with the basic principles of personal data protection, as defined in Article 5.1 of the GDPR, and must be able to demonstrate compliance with these principles. This follows from the principle of accountability set out in Article 5.2 in conjunction with Article 24.1 of the GDPR, as confirmed by the Contentious Chamber.

57. Under Articles 24 and 25 of the GDPR, the defendant must take appropriate technical and organizational measures to ensure and be able to demonstrate that processing is carried out in accordance with the GDPR. In this context, the defendant must effectively apply the principles of data protection, protect the rights of data subjects, and only process personal data that is necessary for each specific purpose of processing.

58. In the course of its investigation, the Inspection Service assessed the extent to which the defendant has taken the necessary technical and organizational measures to comply with these principles of Article 5.1 of the GDPR, particularly the principles of transparency and integrity.

59. The Contentious Chamber found in section II.2.1.3 that there was a violation of the obligations arising from Article 5.1(f) of the GDPR concerning the principle of integrity. The Contentious Chamber also determined in section II.3.3 that there was a violation of the transparency obligations as defined in Articles 12.1, 12.2, 12.6, and Articles 13.1 and 13.2 of the GDPR regarding comprehensible language and the mention of retention periods in the privacy statement.

60. The Contentious Chamber therefore concludes that the defendant could not demonstrate that it had taken the necessary technical and organizational measures to comply with these obligations. The Contentious Chamber concludes that there was a violation of Article 5.2, Article 24.1, and Articles 25.1 and 25.2 of the GDPR concerning the obligations arising from Article 5.1(f) of the GDPR on the one hand, and Article 5.1(a) (transparency), Articles 12.1, 12.2, and 12.6, Articles 13.1 and 13.2, and Articles 14.1 and 14.2 of the GDPR on the other hand.

61. Regarding accountability in relation to compliance with the fundamental principles of the GDPR as set out in Article 5.1(b) to (e) inclusive of the GDPR, the Contentious Chamber finds that there is insufficient evidence to determine that there has been a violation of these articles.

II.5. Article 30.1 of the GDPR

15 Decision on the Merits 34/2020 of June 23, 2020, available via the following link:

<https://www.autoriteprotectiondonnees.be/professionnel/publications/decisions>.

Decision on the Merits 136/2023 - 15/22

62. Under Article 30 of the GDPR, every data controller must maintain a record of processing activities carried out under its responsibility. Article 30.1(a) to (g) inclusive of the GDPR states that regarding processing carried out as a data controller, the following information must be available:

- a) the name and contact details of the data controller and any joint controllers, and, where applicable, the representative of the data controller and the data protection officer;
- b) the purposes of the processing;
- c) a description of the categories of data subjects and the categories of personal data;
- d) the categories of recipients to whom the personal data have been or will be disclosed, including recipients in third countries or international organizations;
- e) where applicable, the transfers of personal data to a third country or to an international organization, including the identification of that third country or international organization and, in the case of transfers referred to in Article 49.1, paragraph 2 of the GDPR, the documents evidencing the existence

of appropriate safeguards;

f) where possible, the envisaged time limits for erasure of the different categories of data;

g) where possible, a general description of the technical and organizational security measures referred to in Article 32.1 of the GDPR.

63. In order to effectively apply the obligations contained in the GDPR, it is essential that the data controller (and processors) have an overview of the personal data processing activities they carry out. This record thus primarily serves as a tool to assist the data controller in complying with the GDPR for the various data processing activities it performs, as the record makes the main characteristics of these processing activities visible. The Contentious Chamber considers that this record of processing activities is an essential instrument in the context of the aforementioned accountability (Article 5.2 and Article 24 of the GDPR) and that this record underpins all obligations imposed by the GDPR on the data controller. It is therefore important that it is complete and accurate.

64. Regarding the defendant's record of processing activities, the Inspection Service makes the following findings. The record of processing activities of the

Decision on the Merits 136/2023 - 16/22

the defendant does not meet the minimum requirements set out in Article 30.1 of the GDPR.

Specifically, the following mandatory mentions are lacking:

a) the contact details of the defendant and the data protection officer (see Article 30.1 a) of the GDPR); and

b) a description of the categories of data subjects and categories of personal data (see Article 30.1 c) of the GDPR).

65. In its conclusions, the defendant does not dispute the findings of the Inspection Service.

However, the defendant emphasizes that after becoming aware of the Inspection Service's report, the necessary efforts were made to adapt the record of processing activities in accordance with the obligations arising from the GDPR.

66. The defendant has submitted the adapted record of processing activities. The Contentious Chamber notes that in this adapted record of processing activities, the contact details of the data controller and the data protection officer are included, as well as a description of the categories of data subjects and categories of personal data.

67. The Contentious Chamber emphasizes, however, that the defendant made efforts to comply with the obligations under Article 30 of the GDPR, albeit after receiving the remarks from the Inspection Service.

68. The Contentious Chamber therefore finds that at the time of the Inspection Service's investigation, the record of processing activities did not meet the requirements of Article 30 of the GDPR, thus constituting a violation of Article 30 of the GDPR. The fact that this has been rectified in the meantime does not change this.

II.6. Article 38.1 and 38.3 of the GDPR and Article 39.1 of the GDPR

II.6.1. Findings in the Inspection Report

69. The report from the Inspection Service finds that the defendant did not comply with the requirements regarding the role of the data protection officer under Articles 38.1 and 38.3 of the GDPR, nor the tasks of the data protection officer under Article 39.1 of the GDPR.

70. Regarding the data protection officer, the Inspection Service makes the following findings, summarized as follows:

- the defendant does not demonstrate that its data protection officer was appropriately and timely involved in the context of the complaint. A consultation via MS Teams for which no report is produced is not sufficient to speak of involvement "in an appropriate and timely manner" (documented); and
- the defendant does not demonstrate that its data protection officer actually reports at the highest level of the defendant's management, namely the Y council.

II.6.2. Position of the Defendant

71. Regarding the Inspection Service's finding related to Article 38.1 of the GDPR, the defendant argues that the consultation moments via MS Teams demonstrate that the data protection officer was involved in a timely manner. The defendant received an email from the complainant regarding the

issue raised in the complaint on November 16, 2021. Consultation moments were scheduled on November 18 and 24, 2021, regarding this matter.

72. The defendant contests the findings of the Inspection Service related to Article 38.3 of the GDPR and claims that they are incorrect. As previously indicated, the Inspection Service found on the defendant's website that the Y council was the highest level of the defendant's management body and wrongly concludes, according to the defendant, that the Y council is also the highest level of the defendant's management. The defendant emphasizes that there is a difference between the highest level of the management body and the highest level of the executive body. According to Article 38.3 of the GDPR, the data protection officer must report to the highest level of the executive body and not to the highest level of the management body. The Y council does not manage the staff of Y. Under Article 170 of the Decree of December 22, 2017, on local administration (hereinafter: the local administration decree), the general director ensures the overall management of the services of Y and is at the head of the staff of Y. Neither the permanent office nor the municipal council can interfere in the organization of the management of the services of Y, nor can they manage the staff of Y, as this is the exclusive competence of the general director. The defendant argues that the data protection officer reports to the general director, thus reporting at the highest level of management and acting in accordance with Article 38.3 of the GDPR.

II.6.3. Assessment by the Contentious Chamber

73. The Contentious Chamber recalls that Article 38.1 of the GDPR stipulates that the data controller ensures that the data protection officer is involved, in an appropriate and timely manner, in all issues related to the processing of personal data.

Decision on the Merits 136/2023 - 18/22

74.

The Dispute Chamber notes that the defendant has submitted screenshots demonstrating that MS Teams consultation meetings titled 'Complaint RGPD M.R' took place, based on which the Dispute Chamber cannot establish that the data protection officer was not involved (in a timely manner). The Dispute Chamber therefore finds no violation of Article 38.1 of the GDPR. However, the Dispute Chamber emphasizes that, in light of the responsibility as defined in Article 5.2 and Articles 24 and 25 of the GDPR, a report of these consultation meetings could have better demonstrated that the data protection officer was appropriately and timely involved following the complainant's email.

75.

Article 38.3 of the GDPR states that the data protection officer must report directly to the highest management level of the data controller or the processor. The guidelines from the Data Protection Working Party regarding data protection officers provide the following explanations regarding reporting at the highest management level as referred to in Article 38.3 of the GDPR: "If the data controller or processor makes decisions that are incompatible with the GDPR and the advice of the DPO [data protection officer], the latter should have the opportunity to clearly express his dissenting opinion at the highest management level and to the decision-makers." In this regard, Article 38.3 of the GDPR provides that the data protection officer "reports directly to the highest management level of the data controller or the processor." Such direct accountability ensures that senior management (e.g., the board of directors) is aware of the opinions and recommendations of the DPO that fall within the scope of his mission to inform and advise the data controller or processor.

76.

The Dispute Chamber notes that the defendant claims that under Article 170 of the Local Administration Decree, the general director is competent for personnel matters. However, the Dispute Chamber emphasizes that data protection policy goes far beyond personnel issues. The Dispute Chamber cannot therefore agree with this position of the defendant. The Dispute Chamber recalls that it has previously stated that in a municipality, the College of Mayors and Aldermen is the highest management level in daily operations. Therefore, the data protection officer must report directly to this College, in accordance with Article 38.3 of the GDPR. By analogy with the above, it is also appropriate to note that the data protection officer of Y must report directly to the permanent office, the body that constitutes the highest management level in the daily operations of Y. Considering these elements, the Dispute Chamber concludes that the data protection officer does not report directly to the highest

management level, which constitutes a violation of Article 38.3 of the GDPR.

77.

Based on Article 39.1 of the GDPR, the data protection officer must (a) inform and advise the data controller on the obligations arising from the GDPR or other provisions of Union law or the law of Member States concerning data protection and (b) monitor compliance with the GDPR, other provisions of Union law or the law of Member States concerning personal data protection and the policy of the data controller or processor regarding personal data protection, including with respect to the allocation of responsibilities, awareness and training of staff involved in processing operations, and related audits. The Dispute Chamber notes that the defendant submits various documents demonstrating that the data protection officer has been involved and that he informs and advises the defendant regarding data protection aspects. The Dispute Chamber therefore finds no violation of Article 39.1 of the GDPR.

III. Sanction

78.

Under Article 100 LCA, the Dispute Chamber has the power to:

- 1° dismiss the complaint;
 - 2° order a dismissal;
 - 3° pronounce the suspension of the ruling;
 - 4° propose a settlement;
 - 5° issue warnings and reprimands;
 - 6° order compliance with the requests of the data subject to exercise their rights;
 - 7° order that the concerned party be informed of the security issue;
 - 8° order the freezing, limitation, or temporary or permanent prohibition of processing;
 - 9° order compliance of the processing;
 - 10° order the rectification, restriction, or erasure of data and notification of such to the recipients of the data;
 - 11° order the withdrawal of the accreditation of certification bodies;
 - 12° impose fines;
 - 13° impose administrative fines;
- Decision on the merits 136/2023 - 20/22
- 14° order the suspension of cross-border data flows to another State or an international organization;
 - 15° forward the file to the Public Prosecutor of the King of Brussels, who will inform it of the follow-up actions taken on the file;
 - 16° decide on a case-by-case basis to publish its decisions on the website of the Data Protection Authority.

79.

In assessing the appropriate sanction and/or corrective measure, the Litigation Chamber takes into account the corrective measures that have been taken by the defendant.

80. In these circumstances, the Litigation Chamber decides to issue a reprimand against the defendant, in accordance with Article 100 § 1, 5° of the LCA, regarding:

- the historical violations of Article 5.1.f) of the GDPR concerning the lack of development and implementation of an information security plan. The Litigation Chamber takes into account the approved information security plan that was submitted on June 21, 2023, and the measures that the defendant had already taken after receiving the inspection report;
- the historical violation of Articles 12.2 and 12.6 of the GDPR for failing to facilitate the exercise of the rights of the data subjects by wrongly stating that the data subjects "receive a response to their request no later than 30 days after receiving your request and proof of identity";
- the violations of Article 5.1.a) (transparency), Article 12.1, Article 13.1 and 13.2, and Article 14.1 and 14.2 of the GDPR regarding the unclear mention of necessary information, as well as the non-explicit mention of the retention period in the privacy statement;

- the violations concerning accountability under Article 5.2 of the GDPR and the obligation to take technical and organizational measures to comply with the requirements of the GDPR and to protect the rights of data subjects (Article 24.1 and Article 25.1 and 25.2 of the GDPR), given the historical violations found of Article 5.1.f) of the GDPR on one hand and Articles 12.1, 12.2, 12.6, 13.1 and 13.2, and Articles 14.1 and 14.2 of the GDPR on the other hand;

- the historical violations of Article 30.1 of the GDPR since various mandatory mentions of Article 30.1 of the GDPR were not included in the register of processing activities. In this regard, the Litigation Chamber takes into account that the defendant had already submitted an updated register of processing activities prior to the hearing;

Decision on the merits 136/2023 - 21/22

- the violations of Article 38.3 of the GDPR and more specifically the absence of a direct report at the highest level of management.

81.

The Litigation Chamber proceeds to dismiss the other grievances and findings of the Inspection Service because, based on the facts and the documents in the file, it cannot conclude that there is a violation of the GDPR. These grievances and findings of the Inspection Service are therefore considered to be manifestly unfounded within the meaning of Article 57.4 of the GDPR.¹⁹

IV. Publication of the decision

82.

Given the importance of transparency regarding the decision-making process of the Litigation Chamber, this decision is published on the website of the Data Protection Authority. However, it is not necessary for this purpose that the identification data of the parties be directly communicated.

Under Article 108, § 1 of the LCA, this decision may be appealed to the Market Court (Court of Appeal of Brussels) within thirty days from its notification, with the Data Protection Authority as the defendant.

¹⁹ See point 3.A.2 of the Policy on dismissal of cases by the Litigation Chamber dated June 18, 2021, available at: <https://www.autoriteprotectiondonnees.be/publications/politique-de-classement-sans-suit-e-de-la-chambre-contentieuse.pdf>.

FOR THESE REASONS,

the Litigation Chamber of the Data Protection Authority decides, after deliberation:

-

under Article 100, § 1, 5° of the LCA, to issue a reprimand regarding the historical violation of Article 5.1.f), 5.2, Article 5.1.a) (transparency), Articles 12.1, 12.2 and 12.6, Articles 24.1, Articles 25.1 and 25.2, Article 30.1 and Article 38.3 of the GDPR;

-

to issue a reprimand, under Article 100, § 1, 5° of the LCA, regarding the violation of Articles 13.1 and 13.2, Articles 14.1 and 14.2 and Article 38.3 of the GDPR;

-

to dismiss the other findings without further action, under Article 100, § 1, 1° of the LCA.

Decision on the Merits 136/2023 - 22/22

Such an appeal may be introduced by means of a contradictory application which must include the details listed in Article 1034ter of the Judicial Code²⁰. The contradictory application must be filed with the registry of the Market Court in accordance with Article 1034quinquies of the Judicial Code²¹, or via the e-Deposit IT system of the Justice (Article 32ter of the Judicial Code).

(signed) Hielke HIJMANS

President of the Litigation Chamber

²⁰ The application must contain, under penalty of nullity:

1° the indication of the day, month, and year;

- 2° the name, first name, and domicile of the applicant, as well as, where applicable, their qualifications and national register number or business number;
- 3° the name, first name, domicile, and, where applicable, the capacity of the person to be summoned;
- 4° the subject and a brief statement of the grounds for the application;
- 5° the indication of the judge who is seized of the application;
- 6° the signature of the applicant or their lawyer.

21 The application, accompanied by its annex, is sent, in as many copies as there are parties involved, by registered letter to the clerk of the jurisdiction or filed with the registry.